LABORATUVAR 6 · AS METAL TETRAGON · Laminat Presi

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad	Grup	Tarih

Senaryo: Saat **10:15**. TETRAGON'un internete açık uzak bakım modülüne "admin/admin" servis hesabıyla gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; emniyet teli ve sıcaklık limiti parametreleri henüz doğrulanmadı. Pres çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?
   Ararım: bakım/otomasyon sorumlusu, IT güvenlik, iş güvenliği uzmanı, As Metal servisi. **Eylemler:** (1) Presi güvenli durdur: plakalar açık, pompa ve ısıtıcı kapalı; operatörü uzaklaştır. (2) Uzak bakım modülünün bağlantısını kes; PLC'yi kapatma, resetleme. (3) 03:00 girişini ve gözlemleri saatleriyle not al.

2. **İlk 2 saat:** Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?
   Safety PLC'deki emniyet teli girişi, açılma mesafesi ve sıcaklık limiti onaylı değerlerle karşılaştırılır; tel çekilip pompanın durduğu ve plakaların 2–3 cm açıldığı test edilir. Geçmezse pres çalışmaz. **Kanıt:** PLC/Safety PLC konfigürasyon kopyası, uzak bakım logları, HMI erişim ve sıcaklık kayıtları. **Hesap:** ortak admin/admin hesabı kapatılır, kişisel hesaplar açılır.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?
   Fark edilme saati ve 03:00 girişi; etkilenen ürün (TETRAGON laminat presi, PLC ve firmware sürümü); ne olduğu (varsayılan şifreli hesapla yetkisiz giriş, emniyet teli/sıcaklık limiti değişikliği şüphesi); kötü niyet şüphesi; aynı presin başka fabrikalarda olması; ilk önlemler. Bildirimi üretici yapar.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?
   Kök neden: varsayılan admin/admin şifresi, MFA yok, modül internete açık. **Etki:** emniyet teli veya sıcaklık limitinde ne değişti, yaralanma/yanık var mı, duruş süresi. **Önlem:** onaylı değerlere dönüş + tel testi, modül DMZ'ye, MFA, kişisel hesap, varsayılan kapalı. **Kim:** vardiya sorumlusu zaman çizgisi, bakım geri yükleme, iş güvenliği test onayı, IT log analizi, üretici CRA bildirimi.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?
   Uzak bakım modülü ve firewall logları; admin hesabının tüm giriş kayıtları (IP, saat); HMI erişim kayıtları ve sıcaklık geçmişi; PLC ve Safety PLC'nin olay anındaki, önceki onaylı ve sonraki hâli; emniyet teli test sonuçları; olay zaman çizgisi ve kararlar.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.